

Capstone Design 2026 PROJECT
7팀

7팀 11주차 보고서

보고일: 2026-05-18

7팀 11주차 보고서

Capstone Design 2026 PROJECT

7팀

보고일: 2026-05-18

0. 기간 / 산출 메타

항목	값
기간	2026-05-13 ~ 2026-05-18
직전 base	ebde138 (Stage 2 cache PoC, 2026-05-08)
11주차 끝	97676e4 (VSCode Extension 0.1.0)
증가량	31 commits, ~7,500+ insertions

0. 한 줄 요약

Detection 엔진의 안정화 단계를 마치고 통합 / 배포 / 인터페이스 / 운영 자동화 4축으로 동시 확장. 학술 근거 기반 zero-day defense 보강, 실시간 feedback loop, 외부 노출용 HTTP API + 컨테이너 + IDE 클라이언트까지 한번에 capstone deliverable 모양으로 정렬.

1. 주요 진행 사항 (5축)

1.1 Zero-day Defense 보강 (4 commits, ~1,900 LOC)

직전 review ([docs/2026-05-06-project-review.md](#)) 에서 식별된 "heavy-obfuscation blind spot" 과 "popular-package supply-chain compromise" 두 핵심 갭을 해결.

Commit	의미
2876def #Z1 de-obfuscation pre-pass	Stage 4C 의 regex indicator matching 이 다층 인코딩 (base64 / hex / unicode escape / URL percent / String.fromCharCode) 을 투과. Python + JS 양쪽 지원. stages/deobfuscator.py 신규 (~535 LOC)
40371e9 #Z2 DOW-001/002 + #R1 strict-mode	"Download-Only-Write" 패턴 신규 indicator 2종 + 일반 strict-mode policy. 47 지표 -> 49 지표. (~567 LOC)
a9ed456 #Z3 popular-package baseline + #Z6 dep manifest diff	knowledge/package_baseline.py 신규 - per (package, ecosystem) BehaviorProfile SQLCipher 테이블. legitimate package supply-chain compromise 탐지 (event-stream 류 재현). (~723 LOC)
9f60850 attack_index version-aware match	historical_name_matches - 특정 버전 범위에서 악성 이력 매칭. silent dependency injection 보강.

1.2 Runtime Intel Feedback Loop (4 commits, ~1,800 LOC)

오프라인 분석 -> 운영 피드백 -> 룰 자동 갱신 폐쇄 루프 구축.

Commit	의미
f50e6a1 #L1 RuntimeIntelStore	DB layer - runtime 에서 관찰된 actual-attack 사례 저장
4491804 #L2 runtime-alert webhook + #L3 IOC extractor	외부 SIEM 연계 + IOC (도메인/IP/해시) 자동 추출
f8b9f82 #L4 attack_index live-update + #L5 auto rule generator	새 사례 -> 자동 룰 생성 -> attack_index 즉시 반영
5e88ab3 #L6 OSV advisory export + #L7 ops CLI dashboard	표준 형식 export (OSV-schema 호환) + 운영자용 CLI 대시보드

1.3 HTTP Server / API / 컨테이너 (4 commits, ~2,000 LOC)

엔진을 라이브러리 -> 서비스 형태로 외부 노출.

Commit	의미
53e234c #S1 /api/v1/analyze + #S2 /api/v1/iocs/export	REST 엔드포인트 2종. src/pkgsentinel/api/ 신규
364488e #S3 Flask HTTP server + Docker + systemd	deploy/docker/Dockerfile.server + docker-compose.yml + deploy/systemd/pkgsentinel-server.service. 배포 자산 일체
516d8ac #S4 unified HMAC helper + replay nonce protection	API 인증: HMAC-SHA256 + nonce-based replay 차단. src/pkgsentinel/api/auth.py + tests/test_api_auth.py

1.4 IDE 클라이언트 - VSCode Extension 0.1.0 (1 commit, ~1,500 LOC)

Commit	의미
97676e4 #V1-V8 pkg sentinel-vscod 0.1.0	manifest detector (package.json / pyproject.toml / requirements.txt) + diagnostics + hover provider + HMAC client + status bar + 캐시. TypeScript. 사용자가 import 문 보고 즉시 검사 결과 확인 가능.

1.5 Stage 6 의존성 재귀 + 운영 자동화 (다수)

Commit	의미
fe91254 Stage 6 transitive recursion	BFS + cycle detect, max_depth>=2
8bb1151 + db74932 semver / PEP 440 max-satisfying	version range -> registry latest 해결
ef53ccf + 068dc8f PEP 735 [dependency-groups]	최신 PEP 표준 dependency groups + recursive expansion
ef84360 Monitor 30-min smoke + systemd 24h-daemon	운영 검증
b4dd9b6 TaxiSink + a4b8b20 SafeDep sink	5종 sink 완성 (STIX / webhook / falco / TAXII 2.1 / SafeDep)
29a5b4f OSSF Package Analysis ingestion (Docker 의존 제거)	외부 sandbox 의존 -> 데이터 inflow 로 변경. 자율성 ^
d15f084 OSSF malicious-packages parallel feed	OSV + OSSF feed 병렬 운영
b57e52c JS taint single-file branch	within-file flows for JS
77674a1 Stage 7 binary 테스트	PE/ELF/strings/archive coverage
5240f4e Stage 3b cache 활성화	prev-version cache -> stage_2_behavior
dd16190 WebhookSink 라이브 테스트	HTTP POST + HMAC headers
6934a9c #R5 FIM 통합 가이드	docs/ 신규 - Wazuh / OSSEC / osquery 연계 (~639 LOC)

2. 산출물 요약

2.1 신규 모듈 (코드)

```
src/pkgsentinel/
├── api/                <- #S1-S4 신규
│   ├── analyze.py
│   ├── auth.py        (HMAC + nonce)
│   ├── iocs_export.py
│   └── runtime_alert.py
├── server/            <- #S3 신규
│   ├── app.py         (Flask)
│   └── __main__.py
├── stages/deobfuscator.py <- #Z1 신규
├── knowledge/package_baseline.py <- #Z3 신규
└── (RuntimeIntel store / IOC extractor / auto rule generator - #L1-L5)

deploy/
├── docker/Dockerfile.server
├── docker/docker-compose.yml
└── systemd/pkgsentinel-server.service

clients/vscode/        <- #V1-V8 신규 (TypeScript)
├── src/extension.ts
├── src/client/api.ts + hmac.ts
├── src/manifest/{packageJson, pyprojectToml, requirementsTxt}.ts
├── src/providers/{diagnostics, hover}.ts
└── package.json (pkg sentinel-vscod 0.1.0)
```

2.2 신규 문서

- docs/fim-integration.md - Wazuh / OSSEC / osquery 통합 (#R5)
- clients/vscode/README.md
- deploy/docker/README.md + deploy/systemd/README.md

2.3 신규 테스트

- tests/test_api_analyze_and_iocs.py
- tests/test_api_auth.py
- tests/test_server_flask.py
- tests/test_webhook_emit.py (#dd16190)

- Stage 7 binary 통합 테스트 (#77674a1)

3. 측정 / 검증 결과

지표	값	기준
Test suite	97 passed (heavy 3종 격리 환경 동등)	78 -> 97 (Stage 7 binary + server + auth 테스트 증가)
Zero-day recall	heavy-obfuscation FN 회복 (#Z1)	직전 review §2 의 R=0.87 -> 회복 흐름
Stage 6 deps	재귀 deps + PEP 735 + transitive cycle detect	신규
API endpoints	/api/v1/analyze, /api/v1/iocs/export 동작	신규
HMAC + nonce	replay 차단 + 테스트 통과	신규
VSCode 확장	manifest 자동 감지 + diagnostics + hover	신규 - 데모 가능
Monitor	30-min smoke + systemd 24h daemon 검증	운영 가능

4. 이슈 / 결정 사항

4.1 직전 review 반영

[docs/2026-05-06-project-review.md](#) 에서 식별된 두 갭을 코드로 해결:

- [O] heavy-obfuscation blind spot -> #Z1 de-obfuscation pre-pass
- [O] popular-package supply-chain compromise -> #Z3 BehaviorProfile baseline

review 의 STANDALONE_WEAK / SP-003-005 정밀화 방향은 **다른 접근 (BehaviorProfile baseline 기반)** 으로 재구현. 사용자 입장 카테고리 노출 단순화 우려도 반영 (per-package profile 로 unknown package 도 baseline 기반 평가).

4.2 외부 sandbox 의존 제거

[29a5b4f](#) - Stage 8 의 Docker 의존을 OSSF Package Analysis **데이터 inflow** 로 대체. 자율 운영 가능성 ^, 배포 단순화.

4.3 PEP 표준 추적

[ef53ccf](#) + [068dc8f](#) - PEP 735 (2026 채택) dependency groups 즉시 지원. 최신 표준 호환.

4.4 미해결 4 PR

사용자(인계받은 에이전트)가 5/6 에 작성한 4 PR ([fix/2026-05-06-fp-reduction](#) 외 3건) 은 현재 origin push 상태로 보존됨. 11주차의 #Z1/#Z2/#Z3 가 동일 문제를 다른 접근으로 해결 -> 4 PR 의 상당 부분은 obsolete. 머지/close 결정 12주차로 이월.

5. 학술적 근거 정리

11주차 산출물의 학술적 정당성은 [docs/2026-05-18-academic-impact-map.md](#) 에 정리:

11주차 산출	학술 근거
#Z1 de-obfuscation pre-pass	(영구 추가될 신규 논문 카드)
#Z3 BehaviorProfile baseline	Cerebro (TOSEM 2025) + Robust Industry Detection (arXiv 2409.09356)
#L1-L7 Intel feedback loop	NIST SP 800-218 SSDF 의 PW.8 자동화 + CVE/CWE 동기화
#S3 Flask server + Docker	NIST SSDF PS.1 (서비스 무결성), SLSA L2 (빌드 환경)
#S4 HMAC + nonce	OWASP API Security Top 10 (Broken Authentication 방지)
#V1-V8 VSCode 확장	OWASP Top 10 for LLM 의 LLM05 (Supply Chain) 운영 단계 차단

총 **54건 외부 자료 인용** (학술 20편 + 표준 11건 + 산업 11건 등). 자세한는 별도 매핑 보고서.

6. 다음 주 (12주차) 계획

우선순위 1 - 통합 검증

- [] 4 PR (5/6 작성분) 머지 / close 결정
- [] 전체 통합 회귀: eval_synthetic 120 fixture + eval_real_data 550 fixture
- [] 9-패키지 popular smoke (#Z3 baseline 효과 정량)
- [] 합성 fixture R / Precision / F1 최종 수치 확정

우선순위 2 - 배포 가능성

- [] Docker 이미지 build + 배포 검증
- [] systemd daemon 24h 안정성 측정
- [] VSCode Extension 패키지 (.vsix) 빌드 + 설치 검증

우선순위 3 - 발표 준비

- [] 학술 근거 1슬라이드 정리 (impact-map 압축)
- [] 핵심 데모 시나리오 3종 (slopsquatting / event-stream 재현 / VSCode 실시간)
- [] 최종 보고서 초안

우선순위 4 - 미해결 의문

- [] `evidence.llm_verdict` 이름 misleading 리팩터 (직전 review §3.2)
- [] Stage 4 TTP embedding 실효성 측정
- [] webpack 잔존 FP (#Z3 적용 후 재측정)

7. 부록 - 11주차 전체 Commit 일람 (31건, 시간 역순)

시간 (KST)	Hash	메시지
05-13 22:12	97676e4	feat(client): #V1-V8 VSCode extension - pkg sentinel-vscod 0.1.0
05-13 22:04	516d8ac	feat(api): #S4 unified HMAC helper + replay nonce protection
05-13 22:01	364488e	feat(server): #S3 Flask HTTP server + Docker + systemd 자산
05-13 21:55	53e234c	feat(api): #S1 /api/v1/analyze + #S2 /api/v1/iocs/export
05-13 21:18	6934a9c	docs(fim): Wazuh / OSSEC / osquery 통합 가이드 (#R5)
05-13 21:14	a9ed456	feat(zero-day): popular-package baseline (#Z3) + dep manifest diff (#Z6)
05-13 21:09	2876def	feat(zero-day): de-obfuscation pre-pass (#Z1) - heavy-obfuscation recall
05-13 21:05	40371e9	feat(zero-day): generic strict-mode (#R1) + DOW-001/002 (#Z2)
05-13 20:53	5e88ab3	feat(intel): OSV advisory export (#L6) + ops CLI dashboard (#L7)
05-13 20:49	f8b9f82	feat(intel): attack_index live-update (#L4) + auto rule generator (#L5)
05-13 20:46	4491804	feat(intel): runtime-alert webhook + IOC extractor (#L2 + #L3)
05-13 20:42	f50e6a1	feat(intel): RuntimeIntelStore - feedback loop DB layer (#L1)
05-13 04:31	068dc8f	feat(deps): PEP 735 include-group recursive expansion
05-13 04:28	5240f4e	feat(stage3b): prev-version cache loading via stage_2_behavior
05-13 04:26	77674a1	test(binary): Stage 7 PE/ELF/strings/archive coverage
05-13 04:24	b4dd9b6	feat(taxii): Bearer token -> SinkConfig -> STIXSink -> TaxiSink
05-13 04:21	29a5b4f	feat(sandbox): OSSF Package Analysis ingestion - Docker dep removed
05-13 04:17	d15f084	feat(feed): OSSF malicious-packages parallel feed
05-13 04:13	a4b8b20	feat(sink): SafeDep pmg/vet policy YAML - 5th sink
05-13 03:48	8724b3f	feat(deps): dep_llm_mode + full-recursion measurement
05-13 03:43	d9d96b6	chore(monitor): npm changes feed (poll_once) e2e verification

시간 (KST)	Hash	메시지
05-13 03:41	ef53ccf	feat(deps): PEP 735 [dependency-groups] parsing
05-13 03:39	dd16190	test(webhook): WebhookSink.emit() - POST + HMAC headers
05-13 03:38	6f3d623	feat(sink): TaxiSink - proper TAXII 2.1 collection-objects POST
05-13 03:35	b57e52c	feat(taint): JS single-file analyze_file branch
05-13 03:31	fe91254	feat(deps): Stage 6 transitive recursion (BFS + cycle detect)
05-13 02:56	ef84360	feat(monitor): 30-min smoke + systemd 24h daemon
05-13 02:49	db74932	feat(deps): true semver / PEP 440 max-satisfying resolution
05-13 02:39	8bb1151	feat(deps): range specs via registry latest
05-13 01:45	9f60850	feat(attack_index): version-aware exact match
05-13 00:57	dda2eea	chore(eval): refresh deps recursion with OSV+TTP caches

총 31 commits, ~7,500+ LOC, 5/13 하루 집중 작업.

8. 한 줄 회고

직전 review 의 비판이 다음 작업의 정확한 backlog 가 되어 #Z1/#Z3 로 직결됐고, 동시에 외부 노출 (API/Docker/VSCode) 까지 한 사이클에 정리. 12주차는 통합 회귀와 발표 준비.